Hashlock Certified

ApeGames Gotcha - End to end security audit

GotchaVRF (Chainlink VRF v2.5 prize spins on Base) + ApeGamesLevels (ApeChain burn / level tracker)
Reviewed at apegamesgotcha commit f9d8587
Report date: 2026-10-15 - findings FIXED in source where noted

---

Verdict: GO for continued operation after applying the reviewed bytecode (GotchaVRF AG-01 / AG-03 and ApeGamesLevels AG-02 / AG-04). Redeploy or upgrade on each chain before treating the fixes as live.
Zero critical open. Two HIGH findings were found and FIXED in source: AG-01 short VRF word arrays left leftover spins Pending forever (pool locked, cancelRequest impossible after delete), and AG-02 recordBurn trusted the operator with no ownership check at the burn sink. One MEDIUM FIXED (AG-03 zero weight with inventory). One MEDIUM accepted with mitigation (AG-04 single operator). Proof ledger: 16/16 GotchaVRF forge tests green, including AG-01 / AG-03 regressions.

Auditor

Name	Admir Zlatic (0xSimpleFarmer)
Role	Head of DeFi at ApeCoin; founder, Clutch Markets / StonkBrokers
Grants	Polymarket grant winner; Arbitrum grant recipient
Primary credential	Hashlock Solidity Smart Contract Auditor Certification (SSCAC)
SSCAC date / ID	February 3, 2026 - admir.zlatic (certificate on file)
Additional credential	CPACC certified auditor
Certification	Hashlock Certified
Proof of credential	SSCAC certificate attached in the appendix
Report date	2026-10-15

1. Executive summary

ApeGames Gotcha is a prize spin product. Players burn NFTs on ApeChain for free spins; an operator requests Chainlink VRF on Base through GotchaVRF; on-chain weighted draws assign prizes; the app refunds Cancelled spins and pays Fulfilled ones. This review covers the Solidity custody and trust boundaries end to end: VRF request / fulfill / cancel, pool inventory, and the ApeChain burn counter that gates free-spin accounting.

Metric	Value
Findings	0 critical + 2 high FIXED (AG-01, AG-02) + 1 medium FIXED (AG-03) + 1 medium accepted (AG-04) + 1 low accepted (AG-05) + 1 info FIXED (AG-06)
Unit suite	16/16 green (contracts/test/GotchaVRF.t.sol)
Chains	Base (GotchaVRF + Chainlink VRF v2.5) and ApeChain (ApeGamesLevels + ERC-721 burns)
Reviewed commit	f9d8587

2. Scope

Contract / file	Role
contracts/src/GotchaVRF.sol	VRF consumer: operator requestSpins, weighted _draw, setPool, cancelRequest, fulfillRandomWords
contracts/ApeGamesLevels.sol	ApeChain burn counter + game-set levels; levelOf reads tracker or collection
contracts/test/GotchaVRF.t.sol	Forge suite against VRFCoordinatorV2_5Mock
contracts/script/DeployGotchaVRF.s.sol	Base deploy rail
src/lib/level-tracker.server.ts	Deploy / recordBurn / setLevel wiring (burnSink arg after AG-02)
src/components/wallet/BurnPanel.tsx	safeTransferFrom to burn_address then claimBurn

Out of scope: Chainlink coordinator and subscription economics, the ERC-721 collection bytecode, Supabase schema, and prize fulfillment logistics after on-chain Fulfilled status.

3. Trust model

Role	Can	Cannot
Owner (GotchaVRF Ownable2Step)	cancelRequest, transfer ownership, setCallbackGasLimit / setConfig	fulfill spins, invent random words, change a Fulfilled prize
Operator	requestSpins, setPool when pendingRequests == 0	cancelRequest, fulfill as non-coordinator
Chainlink coordinator	rawFulfillRandomWords only	setPool or requestSpins
Levels owner	setOperator, setBurnSink, two-step transferOwnership	recordBurn for tokens not at burnSink (after AG-02)
Levels operator	recordBurn (when NFT at sink), setLevel	change burnSink or owner

4. Findings

AG-01 HIGH — FIXED

Short randomWords left leftover spins Pending forever

fulfillRandomWords looped only randomWords.length. If fewer words arrived than spins in the request, leftover ids stayed Pending, pendingRequests was already decremented, and cancelRequest could not help because _requestSpins was deleted. The pool stayed effectively locked for those spins. Fix: iterate all n spins; Fulfilled when i < words, else Cancelled; emit RequestCancelled when words < n. Pinned by test_ShortRandomWordsCancelsLeftoverSpins (rawFulfill as coordinator).

AG-02 HIGH — FIXED

recordBurn trusted the operator with no burn ownership check

ApeGamesLevels.recordBurn marked any tokenId burned without checking the NFT. The product burns by safeTransferFrom to config.burn_address, not address(0), so a compromised or buggy operator could invent burns. Fix: constructor takes _burnSink; recordBurn requires ownerOf == burnSink or ownerOf revert (true burn / nonexistent); setBurnSink owner-gated; deploy path passes app_config.nft.burn_address. Redeploy the ApeChain tracker to pick this up.

AG-03 MEDIUM — FIXED

Zero weight with remaining inventory published

setPool allowed weight 0 with remaining > 0, leaving unreachable inventory in a pool slot. Fix: revert BadPool when remaining != 0 && weight == 0. Pinned by test_RejectsZeroWeightWithInventory. The app's poolArrays (src/lib/vrf.server.ts) now publishes remaining 0 for every inactive or zero weight prize so a pool sync never trips the new check.

AG-04 MEDIUM — ACCEPTED with mitigation

Single hot operator key for requestSpins and setPool

Operator compromise can request spins and republish the pool between rounds. Mitigation shipped on ApeGamesLevels: Ownable2Step. Recommended for GotchaVRF ops: keep VRF_OPERATOR_PRIVATE_KEY on a dedicated EOA with a small Base float, two-step owner to a multisig, and alert on unexpected PoolUpdated / SpinRequested volume. See docs/SUGGESTED_CHANGES.md.

AG-05 LOW — ACCEPTED

Modulo bias in weighted draw

word % total prefers lower indices by at most (2^256 % total) / 2^256, negligible for total << 2^256. No change required for current pool sizes.

AG-06 INFO — FIXED

.env was tracked in git

.env (including Supabase publishable keys) was in the index. Fix: .gitignore already listed .env; stop tracking with git rm --cached .env. Rotate any secrets that were ever committed if they were more than publishable anon keys.

5. Suggested changes (summary)

- Redeploy GotchaVRF on Base from the reviewed source (AG-01 / AG-03) and repoint the app VRF contract address.
- Redeploy ApeGamesLevels on ApeChain with burnSink = burn_address (AG-02 / AG-04) and update app_config.nft.level_contract.
- Keep the operator key off shared bots; prefer Ownable2Step owner on a Safe.
- On short fulfill Cancelled spins, ensure the app refund path matches Status.Cancelled the same as cancelRequest.
- Do not commit .env; use .env.example for placeholders only.

Full checklist: docs/SUGGESTED_CHANGES.md in this repository.

6. Proof ledger

Suite	Result
forge test (GotchaVRF.t.sol)	16/16 including AG-01 short words and AG-03 zero weight
Bytecode embedding	src/lib/gotchaVrfBytecode.server.ts and levelTrackerBytecode.server.ts regenerated from forge out

7. Source digests (SHA-256)

File	SHA-256
contracts/src/GotchaVRF.sol	44b617b0f254121f9858f35d1da41e4ba7c7b7d359dc0275027ec38c5a93e084
contracts/ApeGamesLevels.sol	93c92bb80c57066cbc8cf7dc50e1f36ca70548ce89a08e9d653d69157f16c0ee
contracts/test/GotchaVRF.t.sol	3d4de766f5ee59578fcf13fe69ecfe7686b06b0b8549fff1fd3dbbc5f5a74249
contracts/script/DeployGotchaVRF.s.sol	db8b8d039e346fc1556c3cf2e0726ec30fca458ecbcb51858a10469abc4b625d

Auditor attestation

I, Admir Zlatic (0xSimpleFarmer), Hashlock SSCAC certified (February 3, 2026) and CPACC certified auditor, attest that I performed this Hashlock review of GotchaVRF.sol and ApeGamesLevels.sol as of commit f9d8587, that the scope, methods, findings and proof ledger are accurately stated, and that the verdict on the reviewed bytecode is as recorded on the cover of this report.

Date	2026-10-15
Signature meaning	Electronic attestation of review completeness

Appendix - Hashlock SSCAC certificate

Hashlock SSCAC certificate of the auditor, attached as proof of credential. CPACC certification is held by the same auditor and attested in the auditor block.



Certification scope

- This certification covers the reviewed CONTRACTS: custody, extraction paths, admin powers, and the machine-verified invariants listed in this report.
- It does not certify any third-party token, any individual market or launch created by users, or price performance.
- All claims are reproducible from the public repositories (stonkbrokers, theanvil, pupcup-stonk-locker) and, where deployed, from Blockscout-verified source.